MSM ACADEMY

SECTION 9

The certification process



9.1 Certification and certification bodies
9.2 Before the audit
9.3 The initial certification audit
9.4 The certification decision
9.5 Maintaining certification
9.6 Preparing a client for certification

MSM ACADEMY

SECTION 9 · LESSON 9.1

Certification and certification bodies

9.1

What certification is, and who provides it

LESSON 9.1

What certification is, and is not

A third-party statement of conformity

- An impartial, competent third party confirms the ISMS meets ISO/IEC 27001 for a defined scope
- Its value is the confidence it gives customers, regulators and the public
- It is not a guarantee that no incident will ever happen

LESSON 9.1

Principles for certification bodies

Principle	What it protects
Impartiality	Decisions based on objective evidence, free from other interests
Competence	Competent people in every certification function
Responsibility · openness	The client stays responsible for conformity; information is accessible
Confidentiality	Client information protected
Complaints · risk-based approach	Responsiveness to complaints; attention to risks to confidence

LESSON 9.1

Impartiality, and what it means for consultants

Distinct provisions, not one universal rule

- Threats: self-interest, self-review, familiarity, intimidation
- Certification bodies may not offer consultancy, nor internal audits to certified clients
- Time-based restrictions apply only in the specific situations the standard defines

LESSON 9.1

Accreditation, briefly

A concept worth knowing

- Certification bodies can themselves be accredited by accreditation bodies
- Accreditation adds confidence in the certification body’s competence
- The accreditation process itself is outside this course

Certification: two perspectives

Implementer's view

- Explain to clients what certification does and does not prove
- Respect the certification body’s impartiality
- Know which relationships create conflicts

Auditor's view

- Decide only on objective evidence
- Refuse consultancy, while explaining findings
- Manage threats to impartiality

LESSON 9.1 · RECAP

Lesson 9.1 recap

- Certification: impartial, competent third-party confirmation for a scope
- Seven principles, led by impartiality and competence
- Impartiality provisions are distinct, each for defined situations
- Accreditation: a concept, outside this course

LESSON 9.1 · KNOWLEDGE CHECK

Check your understanding

A certification body auditor, asked by a client, explains what a finding means and which requirement it relates to. Is this consultancy?

A Yes: any explanation is consultancy

B Yes, unless the client pays separately

C No: explaining findings and clarifying requirements is permitted

D No, but only during surveillance audits

Check your understanding

A certification body auditor, asked by a client, explains what a finding means and which requirement it relates to. Is this consultancy?

A. Yes: any explanation is consultancy

B. Yes, unless the client pays separately

C. **No: explaining findings and clarifying requirements is permitted**

D. No, but only during surveillance audits

Answer: C

The standard allows exchange of information such as explanation of findings or clarification of requirements. Designing or recommending the solution would be consultancy.

MSM ACADEMY

SECTION 9 · LESSON 9.2

Before the audit

Application, programme, time and team

9.2

Application and application review

1	**Apply**	Client provides scope, sites, processes, outsourcing, standard, any consultancy received
2	**Review**	Information sufficient? Differences resolved? Competence available?
3	**Consider**	Scope, sites, audit time, language, safety, impartiality threats
4	**Decide**	Accept, or decline with documented reasons

LESSON 9.2

The three-year audit programme

When	What
Initial certification	Two-stage audit: stage 1 and stage 2
Year 1 and year 2	Surveillance audits, at least once each calendar year; the first within 12 months of the certification decision
Year 3	Recertification audit, before the certificate expires
Throughout	Programme adjusted for size, complexity, effectiveness and previous results

LESSON 9.2

Audit time and multi-site sampling

Principles only in this course

- Audit time set by the certification body’s documented procedure, considering listed factors
- Factors include complexity, technology and regulation, outsourcing, sites, risks, prior results
- Scheme-specific calculation rules and sampling rules are outside this course

LESSON 9.2

Audit team, plan and roles

Who audits, and how the audit is laid out

- Team selected for the competence the audit needs; technical experts where required
- Observers and guides: agreed roles, no influence on the audit
- Audit plan prepared and communicated; the client can object to team members

Before the audit: two perspectives

Implementer's view

- Give complete, honest application information
- Disclose any consultancy received
- Expect the programme to cover three years

Auditor's view

- Review the application before accepting
- Plan the full cycle
- Record audit time and its justification

LESSON 9.2 · RECAP

Lesson 9.2 recap

- Application and review: accept or decline with reasons
- Three-year programme: two-stage audit, two surveillances, recertification
- Audit time by documented procedure; tables outside this course
- Competent team; plan communicated; client may object

LESSON 9.2 · KNOWLEDGE CHECK

Check your understanding

A client was certified on 15 March. When must the first surveillance audit take place at the latest?

A Within 12 months of the certification decision

B At any time in the following calendar year

C Only after the first internal audit

D At the end of the three-year cycle

Check your understanding

A client was certified on 15 March. When must the first surveillance audit take place at the latest?

A **Within 12 months of the certification decision**

B At any time in the following calendar year

C Only after the first internal audit

D At the end of the three-year cycle

Answer: A

The first surveillance audit after initial certification is no more than 12 months from the certification decision date.

MSM ACADEMY

SECTION 9 · LESSON 9.3

The initial certification audit

9.3

Stage 1, stage 2 and findings

LESSON 9.3

Stage 1: purpose and activities

More than a document review

- Review documented information; understand site conditions and readiness
- Check understanding of the requirements; gather scope, process and legal information
- Agree resources and arrangements for stage 2, and focus its planning
- Check that internal audits and management review are planned and performed

LESSON 9.3

Stage 2

Purpose	Coverage includes
Evaluate implementation, including effectiveness	Conformity to all requirements of the standard
At the client's site(s)	Performance monitoring against objectives and targets
Builds on stage 1 conclusions	Legal, regulatory and contractual compliance; operational control
	Internal auditing and management review; management responsibility for policies

LESSON 9.3

Major and minor nonconformities

Definitions from the certification standard

Major Affects the capability of the management system to achieve its intended results

- E.g. significant doubt about effective control; several minors showing a systemic failure

Minor Does not affect that capability

LESSON 9.3

Closing meeting, report and the client’s response

After stage 2

- Closing meeting: conclusions, recommendation, nonconformities understood, response time agreed
- Client analyses causes; plans correction and corrective action within a defined time
- Certification body reviews them and verifies effectiveness, on documents or on site

LESSON 9.3 · EXERCISE

Exercise: grading certification findings

Northfield Logistics, stage 2 findings:

1 No internal audit has been carried out and no management review has been held.
2 One of 40 sampled leavers' accounts was disabled two days later than the 24-hour rule.
3 Four of five sampled critical supplier contracts lack the security clauses the SoA declares implemented (5.20).

Grade each finding. Then say what must happen before a certification decision.



Pause the video

Then compare with the model answer.

Model answer: grading certification findings

Finding 1	Major: without internal audit and management review, the system’s capability to achieve its results is in doubt
Finding 2	Minor: an isolated lapse in an otherwise working control
Finding 3	Major: most sampled contracts lack a declared control; significant doubt about effective supplier control

Before decision: majors corrected and verified; the minor’s plan reviewed and accepted.

Initial audit: two perspectives

Implementer's view

- Treat stage 1 as a readiness check, not a formality
- Respond to findings with cause analysis
- Meet the agreed timeframes

Auditor's view

- Communicate stage 1 conclusions and concerns
- Grade by the definitions
- Verify majors before recommending

LESSON 9.3 · RECAP

Lesson 9.3 recap

- Stage 1: purposes and activities, not just document review
- Stage 2: implementation and effectiveness, at the client’s sites
- Major affects capability to achieve results; minor does not
- Closing meeting, cause analysis, verified corrective action

LESSON 9.3 · KNOWLEDGE CHECK

Check your understanding

At stage 1, the client has never held a management review. What is the most appropriate action?

A Grade it a major nonconformity immediately

B Record it as an area of concern that could become a nonconformity at stage 2, and consider readiness

C Ignore it until surveillance

D Cancel the certification contract

Check your understanding

At stage 1, the client has never held a management review. What is the most appropriate action?

A. Grade it a major nonconformity immediately

B. Record it as an area of concern that could become a nonconformity at stage 2, and consider readiness

C. Ignore it until surveillance

D. Cancel the certification contract

Answer: B

Stage 1 evaluates readiness, including whether internal audits and management reviews are planned and performed, and communicates areas of concern that could be nonconformities at stage 2.

MSM ACADEMY

SECTION 9 · LESSON 9.4

The certification decision

Who decides, and what is certified

9.4

LESSON 9.4

Who decides, and on what

Separation of audit and decision

- Decision by competent people who did not carry out the audit
- Review: information sufficient; majors corrected and verified; minors’ plans accepted
- Each decision recorded

LESSON 9.4

Certificates, scope and marks

What the certificate says, and how it may be used

- Certificate: client and sites, dates, expiry, unique code, standard and edition, scope, certification body
- The scope must not be misleading or ambiguous
- Marks never on products or packaging in a way that implies product certification

Role play: “Just tell us how to fix it”



Jonas Ekberg IT Manager, Northfield Logistics

“You’ve found the supplier contract problem. Just tell us which tool or consultant to use and we’ll fix it before your decision.”

YOU

Your move: You are the certification auditor. Stay helpful and impartial. What do you say?

LESSON 9.4 · ROLE PLAY

One way to say it

“I understand you want to close this quickly. I can’t recommend a tool or a consultant; that would compromise our impartiality. I can explain the finding and what the requirement expects. Then we need your cause analysis and action plan by the agreed date.”

Why it works

- Acknowledges his urgency
- States the boundary and why
- Offers what is allowed: explanation and the next step

Decision: two perspectives

Implementer's view

- Expect the decision from someone other than the auditors
- Check the certificate scope is accurate
- Use marks within the rules

Auditor's view

- Recommend, never decide
- Never recommend solutions or consultants
- Keep the scope unambiguous

LESSON 9.4 · RECAP

Lesson 9.4 recap

- Decision by people who did not audit
- Majors verified; minors’ plans accepted before deciding
- Certificate content and unambiguous scope; marks not on products
- Explain findings, never prescribe fixes

LESSON 9.4 · KNOWLEDGE CHECK

Check your understanding

The audit team leader who conducted stage 2 also signs the certification decision. What is the issue?

A None: the leader knows the evidence best

B The decision must be made by a committee

C Only the client may decide

D The decision must be made by people different from those who carried out the audit

Check your understanding

The audit team leader who conducted stage 2 also signs the certification decision. What is the issue?

A. None: the leader knows the evidence best

B. The decision must be made by a committee

C. Only the client may decide

D. The decision must be made by people different from those who carried out the audit

Answer: D

Certification decisions are made by competent persons or committees different from those who carried out the audits.

MSM ACADEMY

SECTION 9 · LESSON 9.5

Maintaining certification

Surveillance, recertification and beyond

9.5

LESSON 9.5

Surveillance

Between recertifications

- At least once a calendar year; on site, not necessarily full-system
- Always includes internal audits and management review, previous nonconformities, complaints
- Also effectiveness, improvement, operational control, changes and use of marks

LESSON 9.5

Recertification

Renewing the certificate

- Confirms continued conformity and effectiveness of the whole system
- Reviews the cycle’s surveillance reports; stage 1 if significant changes
- Majors resolved before expiry, or certification is not extended

LESSON 9.5

Special audits

Outside the normal schedule

- Scope extension: review and any audit needed before granting
- Short-notice or unannounced audits: complaints, changes, suspended clients
- Conditions made known in advance; extra care in choosing the team

LESSON 9.5

Suspension, withdrawal, appeals and complaints

When things go wrong

- Suspension: e.g. persistent or serious failure, refusing audits, voluntary request
- Unresolved suspension leads to withdrawal or reduced scope
- Appeals and complaints handled by people not involved, without discrimination

Maintenance: two perspectives

Implementer's view

- Keep the ISMS running between audits
- Report significant changes
- Use appeals and complaints when needed

Auditor's view

- Cover the mandatory items each surveillance
- Plan recertification before expiry
- Act on suspension criteria consistently

LESSON 9.5 · RECAP

Lesson 9.5 recap

- Surveillance yearly, with mandatory items
- Recertification before expiry; majors resolved in time
- Special audits: scope extension, short notice
- Suspension, withdrawal, appeals and complaints

LESSON 9.5 · KNOWLEDGE CHECK

Check your understanding

A certified client refuses to schedule its second surveillance audit. What is the most likely consequence?

A. Nothing until recertification

B. An automatic minor nonconformity

C. Suspension of certification

D. Immediate transfer to another certification body

Check your understanding

A certified client refuses to schedule its second surveillance audit. What is the most likely consequence?

A. Nothing until recertification

B. An automatic minor nonconformity

C. **Suspension of certification**

D. Immediate transfer to another certification body

Answer: C

Not allowing surveillance or recertification audits at the required frequencies is one of the situations in which certification is suspended.

MSM ACADEMY

SECTION 9 · LESSON 9.6

Preparing a client for certification

9.6

The consultant’s view

LESSON 9.6

Readiness, from the certification body’s point of view

What stage 1 will look for

- A clear scope, and documented information that reflects reality
- Internal audits and management review already performed
- Implementation mature enough to evidence over time

LESSON 9.6

The consultant’s boundary

Separate roles, by design

- The consultant prepares the client; the certification body judges independently
- Disclose consultancy on the application; it affects the certification body’s planning
- Never imply certification is easier through a particular body

LESSON 9.6

Choosing a certification body

Questions worth asking

- Can it certify this scope, with competent auditors for the technology?
- How does it manage impartiality and conflicts of interest?
- Is it accredited, and how does it plan audits and handle complaints?

Preparation: two perspectives

Implementer's view

- Check readiness honestly before stage 1
- Disclose consultancy
- Keep out of the certification decision

Auditor's view

- Judge independently of any consultant
- Treat consultancy disclosures as impartiality inputs
- Expect evidence, not presentations

LESSON 9.6 · RECAP

Lesson 9.6 recap

- Prepare against what stage 1 and stage 2 look for
- Internal audit and management review done, not just planned
- Disclose consultancy; never imply easier certification
- Choose a certification body on competence and impartiality

Check your understanding

A consultant tells a client: “Use this certification body; with my connections, certification will be quicker.” What is the problem?

A Such statements threaten impartiality; certification must not be presented as easier through a link

B None, if the consultant is experienced

C Only that the consultant should charge less

D The client must use the consultant’s certification body

Check your understanding

A consultant tells a client: “Use this certification body; with my connections, certification will be quicker.” What is the problem?

- **A** **Such statements threaten impartiality; certification must not be presented as easier through a link**
- **B** None, if the consultant is experienced
- **C** Only that the consultant should charge less
- **D** The client must use the consultant’s certification body

Answer: A

Linking consultancy and certification, or implying certification is easier through a connection, threatens impartiality. Certification bodies must act against such statements.

LESSON 9.6

From Section 9 to Section 11

Rule from Section 9	How Section 11 uses it
Stage 1 purpose and activities	Quenvale’s stage 1 readiness review
Stage 2 coverage	Quenvale’s stage 2 audit
Major and minor definitions	Grading Quenvale’s findings
Corrections, corrective action, verification	What Quenvale must provide before a decision
Decision, surveillance	What happens after the simulated audit

SECTION 9 · SUMMARY

The certification process in one view

- Impartial, competent certification bodies
- Application, three-year programme, two-stage initial audit
- Graded findings, independent decision, unambiguous certificate
- Surveillance, recertification, special audits, suspension

MSM ACADEMY

SECTION 9 COMPLETE

Next: Section 10

Lead Implementer case study and simulation

